

Report di Valutazione della Sicurezza Enterprise – Sicurezza Infrastruttura E-Commerce

Revisione Completa dell'Architettura di Sicurezza, Analisi dell'Impatto sul Business, Controlli Preventivi di

Sicurezza e Strategia di Incident Response

Corso: Cybersecurity Analyst

Modulo: W20D4 (Pratica)

Piattaforma: Epicode

Studente: Emanuele Cestari

Executive Summary

Questo report valuta il livello di sicurezza di un'infrastruttura e-commerce esposta a Internet tramite un'architettura DMZ. La valutazione identifica rischi associati a SQL Injection, Cross-Site Scripting (XSS), propagazione di malware, attacchi DDoS e movimenti laterali verso la rete interna. Il report propone controlli preventivi, protezioni per la continuità operativa, procedure di Incident Response e strategie avanzate di hardening allineate alle moderne best practice di cybersecurity.

1. Analisi dell'Infrastruttura Originale

L'infrastruttura originale espone un'applicazione e-commerce a Internet tramite firewall e DMZ. La DMZ mantiene percorsi di comunicazione verso la rete interna, introducendo un rischio significativo. Se il server web all'interno della DMZ viene compromesso, un attaccante potrebbe tentare:

- movimento laterale;
- escalation dei privilegi;
- propagazione di malware;
- pivoting verso sistemi interni;
- compromissione del database.
-

Schema infrastruttura originale



Minaccia	Impatto	Gravità
SQL Injection	Compromissione database	Alta
XSS	Furto sessione	Media
DDoS	Interruzione servizio	Alta
Propagazione Malware	Infezione rete interna	Critica
Movimento Laterale	Compromissione interna	Critica

2. Controlli Preventivi di Sicurezza

L'infrastruttura richiede molteplici livelli di difesa per mitigare i moderni attacchi alle web application.

Mitigazioni SQL Injection

- Prepared statements e query parametrizzate

- Validazione e sanitizzazione degli input
- Account database con privilegi minimi
- Web Application Firewall (WAF)
- Segmentazione database
- Gestione patch di sicurezza

Mitigazioni Cross-Site Scripting (XSS)

- Output encoding
- Sanitizzazione degli input
- Content Security Policy (CSP)
- Cookie HttpOnly e Secure
- Filtri server-side
- Regole anti-XSS del WAF

Misure preventive aggiuntive

- Monitoraggio IDS/IPS
- Integrazione SIEM
- Logging centralizzato
- Deploy EDR
- Segmentazione VLAN sicura
-

Schema controlli preventivi



Minaccia	Impatto	Mitigazione
SQL Injection	Compromissione DB	Prepared Statements + WAF
XSS	Furto sessione	CSP + Output Encoding
DDoS	Interruzione servizio	CDN + Anti-DDoS

3. Analisi dell’Impatto sul Business – Attacco DDoS

Un attacco DDoS ha reso la piattaforma e-commerce inaccessibile per 10 minuti, causando una perdita finanziaria diretta di 15.000 €, calcolata moltiplicando la spesa media dei clienti al minuto (1.500 €) per la durata dell’interruzione (10 minuti). Oltre a questo, l’attacco ha avuto impatti indiretti significativi, tra cui danni reputazionali, riduzione della fiducia dei clienti, violazioni degli SLA, perdita di ricavi futuri e interruzione delle operazioni.

4. Incident Response – Infezione Malware

Se l’applicazione web nella DMZ viene infettata da malware, la priorità principale è impedire la propagazione verso la rete interna.

Azioni di contenimento

- Isolare il server compromesso all’interno della DMZ.
- blocco comunicazioni DMZ → rete interna;
- disabilitazione regole firewall non necessarie;
- quarantena traffico sospetto.

Attività di rilevamento

- analisi log firewall e server;
- verifica IOC (Indicatori di Compromissione);
- ispezione processi e connessioni sospette;
- utilizzo EDR e antivirus.

Attività di recupero

- ripristino backup puliti;
- patch dei sistemi;
- rotazione credenziali;
- hardening infrastrutturale.

Schema Incident Response



5. Ciclo di Vita dell'Incident Response

Preparazione: Implementare SIEM, EDR, backup, segmentazione e sistemi di monitoraggio.

Rilevamento: Analizzare i log, identificare gli IOC, monitorare il traffico sospetto e rilevare i processi anomali.

Contenimento: Isolare i server infetti nella DMZ e bloccare le comunicazioni.

Eradicazione: Rimuovere il malware, applicare le patch alle vulnerabilità e ruotare le credenziali.

Recupero: Ripristinare i backup e monitorare l'ambiente post-reintegrazione.

Lessons Learned: Documentare l'incidente e migliorare i controlli difensivi.

6. Soluzione Enterprise Integrata Completa

La soluzione finale integra controlli preventivi, mitigazione DDoS, segmentazione e procedure di Incident Response in un'architettura enterprise unificata. Le tecnologie integrate comprendono CDN e sistemi Anti-DDoS, Web Application Firewall (WAF), monitoraggio IDS/IPS, correlazione e alerting SIEM, protezione endpoint EDR, reverse proxy architecture, isolamento database, segmentazione VLAN sicura, logging centralizzato e infrastruttura backup e recovery.

Lo schema dell'architettura enterprise integrata illustra questi componenti.



7. Hardening Aggressivo dell'Infrastruttura

Questa sezione illustra una strategia enterprise fondata sui principi Zero Trust, comprendente:

- Architettura Zero Trust
- Microsegmentazione
- Amministrazione dei Bastion Host

- **Accesso VPN con Multi-Factor Authentication (MFA)**
- **Controllo degli Accessi Basato sui Ruoli (RBAC)**
- **Implementazione di Honeypot nella DMZ**
- **Backup offline immutabili**
- **Pianificazione del Disaster Recovery**
- **Monitoraggio EDR continuo**
- **Analisi SIEM avanzata**
- **Hardening infrastrutturale**



Conclusione

L'architettura proposta potenzia notevolmente la resilienza dell'infrastruttura, minimizza la superficie di attacco e la allinea alle best practice enterprise di cybersecurity. Implementando controlli preventivi, protezione DDoS, procedure di Incident Response, principi Zero Trust e sistemi avanzati di monitoraggio, l'organizzazione può ridurre significativamente il rischio di compromissione, diffusione di malware e downtime dei servizi.